

Threat Analysis Report

แคมเปญการโจมตีที่มีความซับซ้อนสูง
ในการรวมเอาเฟรมเวิร์กมัลแวร์
EtherRAT, TukTuk และแรนซัมแวร์
The Gentlemen

16/05/2026

TLP:CLEAR





สารบัญ

บทสรุปสำหรับผู้บริหาร	3
การวิเคราะห์เชิงเทคนิค	4
Technique Tactics and Procedures (MITRE ATT&CK)	11
Indicator of Compromise (IOCs)	13
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	15
อ้างอิง (References)	17



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์เหตุการณ์การโจมตีทางไซเบอร์ที่ตรวจพบในเดือนเมษายน 2569 ซึ่งดำเนินการโดยกลุ่มอาชญากรรมทางไซเบอร์ที่เกี่ยวข้องกับมัลแวร์ ได้แก่ EtherRAT TukTuk และ แรนซัมแวร์ The Gentlemen การโจมตีเริ่มต้นจากการหลอกลวงให้บุคลากรขององค์กรติดตั้งซอฟต์แวร์ปลอมที่แฝงรหัสอันตราย จากนั้นผู้โจมตีได้แฝงตัวในระบบเครือข่ายขององค์กรเป็นเวลาหลายวัน ก่อนขโมยข้อมูลสำคัญออกไป และปิดท้ายด้วยการลือกระบบเรียกค่าไถ่ทั่วทั้งองค์กรจากการหลอกล่อให้ผู้ใช้ติดตั้งไฟล์ MSI ที่ปลอมแปลงเป็นเครื่องมือ RAMMap ของ Sysinternals เมื่อติดตั้งแล้วจะมีการใช้มัลแวร์ EtherRAT ซึ่งมีเทคนิคพิเศษในการดึงข้อมูลการตั้งค่า Command-and-Control (C2) จากระบบบล็อกเชนของ Ethereum (เทคนิค EtherHiding) ตามมาด้วยมัลแวร์ TukTuk ที่คาดว่าจะสร้างโดย AI เพื่อใช้ในการจารกรรมข้อมูล และจบลงด้วยการแพร่กระจายแรนซัมแวร์ The Gentlemen ไปทั่วทั้งระบบโดเมน

สิ่งที่ทำให้การโจมตีครั้งนี้มีความซับซ้อนเป็นพิเศษ คือการใช้เทคโนโลยีบล็อกเชน Ethereum เป็นช่องทางสื่อสารลับกับระบบควบคุมมัลแวร์ (เทคนิคที่เรียกว่า EtherHiding) ซึ่งทำให้ฝ่ายรักษาความปลอดภัยไม่สามารถตัดการสื่อสารดังกล่าวได้โดยวิธีทั่วไป นอกจากนี้ ผู้โจมตียังใช้มัลแวร์ตัวที่สองชื่อ TukTuk ที่คาดว่าจะสร้างขึ้นด้วยความช่วยเหลือจาก AI เพื่อขโมยข้อมูลผ่านบริการคลาวด์ที่ถูกกฎหมาย ทำให้การตรวจจับยิ่งยากขึ้นไปอีก

จากการวิเคราะห์หลักฐาน กลุ่ม The Gentlemen ปรากฏตัวในช่วงกลางปี 2568 และเติบโตอย่างรวดเร็วในรูปแบบธุรกิจให้เช่าแรนซัมแวร์ โดยอ้างเหยื่อมากกว่า 320 รายทั่วโลก ส่วนใหญ่เป็นองค์กรขนาดใหญ่ในภาคธุรกิจ การผลิต และบริการสุขภาพ ระดับความมั่นใจในการระบุตัวตนผู้โจมตีอยู่ในระดับปานกลาง เนื่องจากหลักฐานทางเทคนิคบางส่วนมีความทับซ้อนกับกลุ่มภัยคุกคามจากเกาหลีเหนือ แต่ยังไม่มีความชัดเจนเพียงพอที่จะยืนยันได้อย่างแน่ชัด

องค์กรควรเร่งดำเนินการมาตรการด้านความมั่นคงปลอดภัยไซเบอร์อย่างครอบคลุม โดยกำหนดนโยบายควบคุมการติดตั้งซอฟต์แวร์และจำกัดสิทธิ์การใช้งานทุกระดับ ควบคู่กับการตรวจสอบและบล็อกการรับส่งข้อมูลที่ผิดปกติ โดยเฉพาะการเชื่อมต่อกับบริการบล็อกเชนและคลาวด์ที่ไม่ได้รับอนุญาต พร้อมทั้งเสริมความแข็งแกร่งให้ระบบตรวจจับภัยคุกคาม ณ จุดปลายทางเพื่อให้สามารถตรวจพบการดัมป์รหัสผ่านและการแพร่กระจายภายในเครือข่าย และดำเนินการทดสอบปรับปรุงแผนรับมือเหตุการณ์ฉุกเฉินด้านไซเบอร์อย่างต่อเนื่อง เพื่อให้องค์กรมีความพร้อมในการตอบสนองต่อการโจมตีที่ซับซ้อนและลดผลกระทบได้อย่างมีประสิทธิภาพ

การวิเคราะห์เชิงเทคนิค

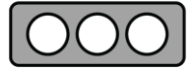
ข้อมูลพื้นฐานของเหตุการณ์ (Event Metadata)

ชื่อเหตุการณ์	EtherRAT & TukTuk C2 และแรนซัมแวร์ The Gentlemen
วันที่ตรวจพบ	เมษายน 2569 (April 2026)
แหล่งที่มารายงาน	The DFIR Report Flash Alert (11 พฤษภาคม 2569)
ประเภทภัยคุกคาม	Ransomware-as-a-Service (RaaS) / Multi-Stage Intrusion
มัลแวร์หลัก	EtherRAT, TukTuk, The Gentlemen Ransomware
แพลตฟอร์มที่ถูกโจมตี	Windows (Domain Environment, Active Directory)
วิธีการเข้าถึงเบื้องต้น	ไฟล์ MSI installer ปลอมเป็น Sysinternals RAMMap
เป้าหมาย	องค์กรขนาดใหญ่ในด้าน ธุรกิจ, การผลิต, สุขภาพ, ประกันภัย, ก่อสร้าง
ผลกระทบสูงสุด	การเข้ารหัสข้อมูลทั่วทั้ง Domain และขโมยข้อมูลออกไปยัง Wasabi Cloud Storage

ภาพรวมเหตุการณ์และพื้นหลัง

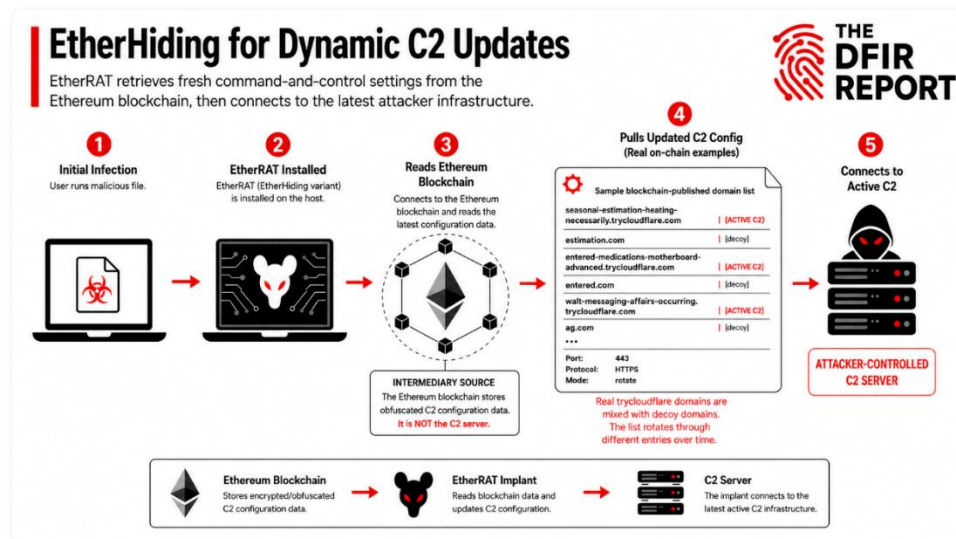
ในเดือนเมษายน 2569 The DFIR Report ได้รายงานการบุกรุกที่มีความซับซ้อนสูง ซึ่งเชื่อมโยงกับแคมเปญที่ Atos รายงานไว้ก่อนหน้านี้ โดยเหตุการณ์เริ่มต้นจากการที่ผู้ใช้ถูกหลอกให้ติดตั้งไฟล์ MSI ที่ปลอมแปลงเป็นเครื่องมือ RAMMap ของ Sysinternals ซึ่งเป็นโปรแกรมที่บุคลากรด้านไอทีและผู้ดูแลระบบมักใช้งานในชีวิตประจำวัน การโจมตีนี้แสดงให้เห็นถึงรูปแบบการคัดเลือกเหยื่อที่มุ่งเป้าไปยังบุคลากรที่มีสิทธิ์ระดับสูงในองค์กรโดยเฉพาะ

เหตุการณ์นี้มีความโดดเด่นด้านเทคนิคในหลายมิติ ได้แก่ การใช้ EtherRAT ซึ่งเป็น Backdoor ที่เขียนด้วย Node.js และอาศัยเทคนิค EtherHiding ในการตั้งที่อยู่เซิร์ฟเวอร์ C2 จาก Ethereum Smart Contracts แทนการฝังค่า C2 ไว้ในโค้ดโดยตรง ทำให้การปิดกั้นโครงสร้างพื้นฐานของผู้โจมตีทำได้ยากมาก ต่อมาผู้โจมตีได้ติดตั้งมัลแวร์เฟรมเวิร์ก TukTuk ซึ่งนักวิจัย Evangelos G. ระบุว่าน่าจะสร้างขึ้นโดยใช้ปัญญาประดิษฐ์ (AI-generated) ถือเป็นครั้งแรกที่พบการใช้มัลแวร์ประเภทนี้ในแคมเปญ Ransomware จริง ก่อนจะจบลงด้วยการแพร่กระจายแรนซัมแวร์ The Gentlemen ไปทั่วทั้งโดเมนผ่าน Group Policy Object (GPO) ที่เป็นอันตราย ภายในระยะเวลาเพียงสามวันนับจากการบุกรุกครั้งแรก



ระยะเริ่มต้นและการทำงานของ EtherRAT

หลังจากผู้ใช้งานไฟล์ MSI ที่ปลอมแปลงเป็น RAMMap มัลแวร์ EtherRAT จะดาวน์โหลด Node.js runtime แบบพกพาผ่าน CURL และรัน JavaScript payload ที่ผ่านการพรางโค้ด (Obfuscated) พร้อมกันนั้น มัลแวร์จะสร้างความคงอยู่ในระบบโดยเพิ่ม Registry Run Key ชื่อ "AppResolver" เพื่อให้ตัวมันทำงานโดยอัตโนมัติทุกครั้งที่เปิดเครื่อง จากนั้น EtherRAT จะเชื่อมต่อกับบริการ 1rpc.io เพื่อดึงข้อมูลที่อยู่ Command-and-Control (C2) จาก Ethereum Smart Contracts ผ่านเทคนิค EtherHiding แล้วสร้างช่องทางการสื่อสารผ่าน TryCloudflare Tunnel พร้อมปล่อยโดเมนหลอกลวง (Decoy Domains) ออกมาพร้อมกันเพื่อขัดขวางการวิเคราะห์ ก่อนจบขั้นตอนนี้ ผู้โจมตีได้ทำการสำรวจเครือข่าย (Reconnaissance) โดยใช้เครื่องมือพื้นฐานของ Windows และ SoftPerfect Network Scanner เพื่อตรวจสอบสภาพแวดล้อมระบบเป้าหมาย



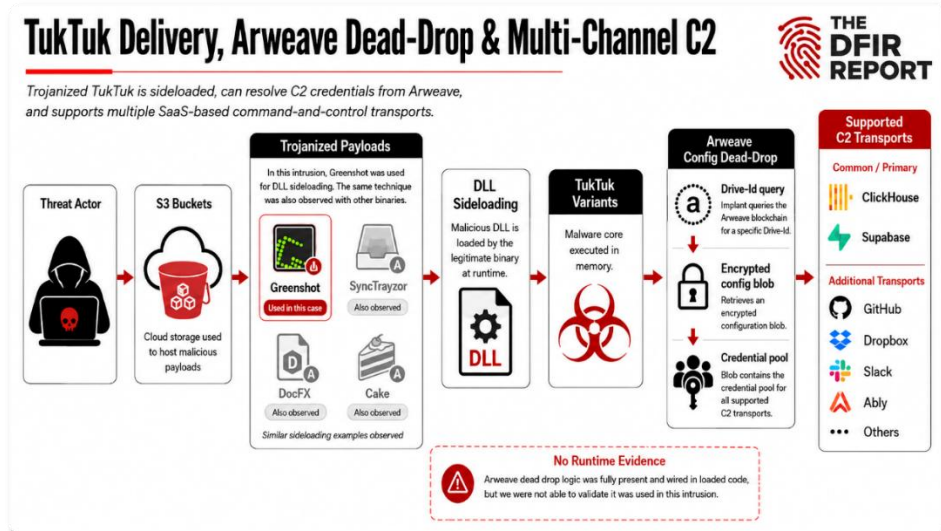
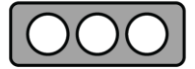
[ภาพที่ 1 อธิบายกระบวนการ EtherHiding สำหรับการอัปเดต C2]

ลำดับที่ 1-2: ผู้ใช้ถูกบุกรุกจากการรันไฟล์อันตราย ทำให้ EtherRAT ถูกติดตั้งลงบนเครื่อง

ลำดับที่ 3: มัลแวร์อ่านข้อมูลบน Ethereum Blockchain ซึ่งทำหน้าที่เป็นตัวกลาง (Intermediary Source) ในการเก็บข้อมูล C2 ที่ถูกเข้ารหัสพรางไว้

ลำดับที่ 4: ดึงการตั้งค่า C2 ล่าสุด (เป็นโดเมนของ TryCloudflare เช่น necessarily.trycloudflare[.]com)

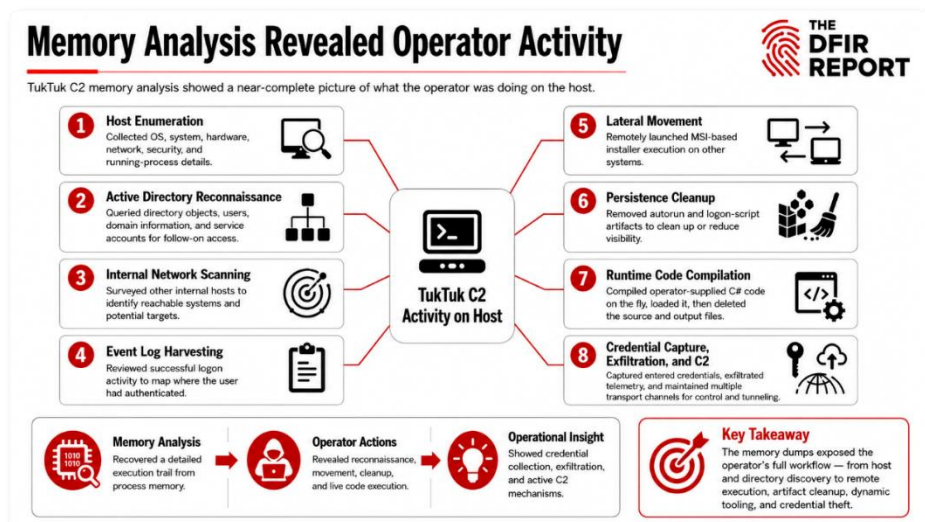
ลำดับที่ 5: เชื่อมต่อไปยังเซิร์ฟเวอร์ C2 ของผู้โจมตีที่ทำงานอยู่



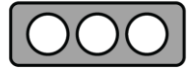
[ภาพที่ 2 แสดงแผนภาพการส่งผ่านมัลแวร์ TukTuk และการสื่อสารแบบ Multi-Channel]

การส่งผ่านมัลแวร์ TukTuk และโครงสร้างพื้นฐานของ C2

ผู้โจมตีดาวน์โหลดมัลแวร์ TukTuk จาก S3 Buckets และติดตั้งผ่านเทคนิค DLL Sideload โดยแอบแฝงไปกับแอปพลิเคชันที่น่าเชื่อถือ เช่น Greenshot, SyncTrayzor, DocFX และ Cake ทำให้โปรแกรมปกติเหล่านี้โหลดไลบรารีอันตราย (TukTuk Variants) เข้าสู่หน่วยความจำโดยที่ผู้ใช้ไม่รู้ตัว ช่องทางการสื่อสาร C2 หลักของ TukTuk ใช้แพลตฟอร์ม SaaS ที่ถูกต้องตามกฎหมาย ได้แก่ ClickHouse และ Supabase ส่วนช่องทางสำรองใช้ Ably, Dropbox, GitHub Issues และ HTTP ธรรมดา นอกจากนี้ มัลแวร์ยังใช้บล็อกเชน Arweave เป็น Dead-drop Resolver เพื่อดึงไฟล์ Config ที่เข้ารหัสไว้ซึ่งบรรจุข้อมูลการเข้าถึง (Credentials) สำหรับช่องทาง C2 ต่างๆ วิธีนี้ทำให้ TukTuk สามารถเปลี่ยนช่องทางสื่อสารได้ตลอดเวลาโดยไม่จำเป็นต้องอัปเดตตัวมัลแวร์เอง



[ภาพที่ 3 แสดงแผนภาพหน่วยความจำที่แสดงขั้นตอนที่ผู้โจมตีทำบนเครื่องจาก TukTuk C2]

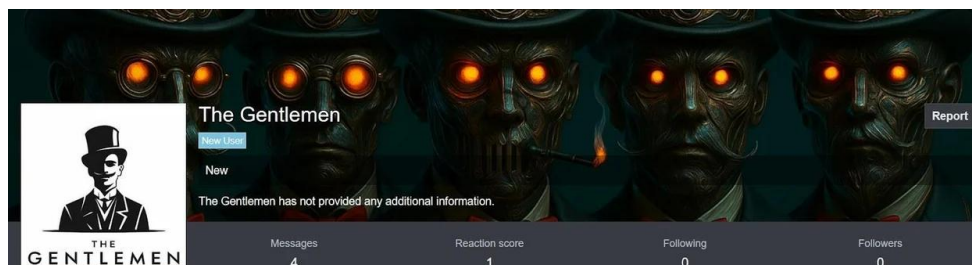


การยกระดับสิทธิ์และการเตรียมการฝังแรนซัมแวร์

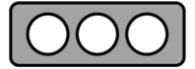
ในขั้นตอนนี้ ผู้โจมตีเริ่มด้วยการขโมย Credential โดยใช้เทคนิค Kerberoasting และการดัมป์หน่วยความจำของ LSASS ผ่านไลบรารี comsvcs.dll เพื่อให้ได้มาซึ่ง Hash ของบัญชีผู้ใช้ระดับสูง จากนั้นจึงนำบัญชีเหล่านั้นมาใช้ในการเคลื่อนที่ภายในองค์กร (Lateral Movement) ผ่านเครื่องมือรีโมท GoTo Resolve รวมถึงโปรโตคอล RDP, SMB, WinRM และ NetExec เพื่อควบคุมเซิร์ฟเวอร์และ Domain Controllers ต่างๆ ทั้งทั้งเครือข่าย ระหว่างนั้น ผู้โจมตีใช้เครื่องมือ Rclone ขโมยข้อมูลสำคัญขึ้นสู่ Wasabi Cloud Storage ของตนเอง และก่อนที่จะปล่อยแรนซัมแวร์ในขั้นสุดท้าย ได้ดำเนินการล้างหลักฐานโดยปิด Microsoft Defender, ลบ Shadow Copies เพื่อป้องกันการกู้คืนข้อมูล และลบ Event Logs ทั้งหมดออกจากระบบ

บทสรุป และ การลงแรนซัมแวร์ The Gentlemen

ในขั้นตอนสุดท้าย ผู้โจมตีสร้าง Group Policy Object (GPO) อันตรายเพื่อสั่งให้ทุกเครื่องในโดเมนดาวน์โหลดและรันแรนซัมแวร์ The Gentlemen จากแชร์โฟลเดอร์ SYSVOL และ NETLOGON ผ่าน Scheduled Tasks ผลที่ตามมาคือระบบทั่วทั้งเครือข่ายถูกเข้ารหัสลับพร้อมกัน มีการทิ้งบันทึกเรียกค่าไถ่ไว้ทุกเครื่อง และเปลี่ยนภาพพื้นหลังหน้าจอเป็นข้อความแจ้งเตือนการเรียกค่าไถ่ แคมเปญนี้รวมเอาเทคโนโลยี Web3 แพลตฟอร์ม SaaS และเครื่องมือ Admin ของระบบเข้าไว้ด้วยกันอย่างชาญฉลาด ทำให้การตรวจจับด้วยวิธีการรักษาความปลอดภัยทั่วไปทำได้ยากมาก



[ภาพที่ 4 การแพร่กระจาย (Deployment) ของแรนซัมแวร์ Gentlemen ผ่านกลุ่ม]



กระบวนการโจมตี (Attack Flow)

การเข้าถึงระบบและการเริ่มทำงาน (Initial Access & Execution)

การโจมตีเริ่มต้นจากการที่ผู้ใช้งานไฟล์ MSI installer ที่เป็นอันตราย ซึ่งปลอมแปลงเป็นเครื่องมือ RAMMap ของ Sysinternals เมื่อถูกเรียกใช้งาน มัลแวร์จะดาวน์โหลด Node.js runtime ผ่าน CURL เพื่อรัน JavaScript payload ที่ผ่านการพรางโค้ด (Obfuscated) และในขั้นตอนเดียวกันนี้ มัลแวร์จะสร้างความคงอยู่ในระบบโดยเพิ่ม Registry Key ชื่อ "AppResolver" ไว้ใน Run key เพื่อให้ตัวมันทำงานโดยอัตโนมัติทุกครั้งที่มีการเปิดเครื่อง

การควบคุมด้วยเทคโนโลยี Web3 (First-Stage C2: EtherRAT)

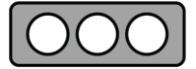
มัลแวร์ใช้เทคนิค EtherHiding โดยวิธีข้อมูลการตั้งค่า Command-and-Control (C2) จาก Ethereum Smart Contracts แทนการฝังค่าไว้ในโค้ดโดยตรง จึงทำให้ไม่สามารถยึดหรือบล็อกโครงสร้างพื้นฐานของผู้โจมตีได้ด้วยวิธีทั่วไป ข้อมูลที่ได้จากบล็อกเชนจะถูกใช้สร้างช่องทางสื่อสารผ่าน TryCloudflare Tunnel พร้อมกับการสร้างโดเมนหลอก (Decoy Domains) จำนวนมากขึ้นพร้อมกันเพื่อปกปิดเส้นทางการสื่อสารที่แท้จริงและขัดขวางการวิเคราะห์

การสำรวจระบบและการติดตั้งมัลแวร์ขั้นที่สอง (Reconnaissance & TukTuk Deployment)

ผู้โจมตีใช้เครื่องมือพื้นฐานของ Windows และ SoftPerfect Network Scanner เพื่อสำรวจเครือข่าย ตรวจสอบสถานะ Antivirus ค้นหาข้อมูลผู้ใช้ผ่าน LDAP และทำความเข้าใจโครงสร้าง Domain จากนั้นจึงติดตั้งเฟรมเวิร์กมัลแวร์ TukTuk (ซึ่งนักวิจัยระบุว่าน่าจะสร้างขึ้นโดยใช้ AI) ผ่านเทคนิค DLL Sideloads โดยแฝงไฟล์ไปกับแอปพลิเคชันที่น่าเชื่อถือ เช่น Greenshot, SyncTrayzor, DocFX และ Cake TukTuk จะสื่อสารผ่านแพลตฟอร์ม SaaS เช่น ClickHouse และ Supabase รวมถึงใช้บล็อกเชน Arweave เป็นแหล่งสำรองข้อมูลการตั้งค่า (Dead-drop resolver)

การขโมยสิทธิ์และการเคลื่อนที่ภายใน (Credential Access & Lateral Movement)

ผู้โจมตีสกัดรหัสผ่านและข้อมูลบัญชีโดยใช้วิธี Kerberoasting และการดั้มพ์หน่วยความจำของ LSASS เพื่อให้ได้มาซึ่ง Hash ของบัญชีผู้ใช้ระดับสูง จากนั้นจึงใช้บัญชีที่ได้มาติดตั้งเครื่องมือรีโมท GoTo Resolve เพื่อควบคุมเซิร์ฟเวอร์และ Domain Controllers ตัวอื่น ก่อนขยายผลไปยังระบบอื่น ๆ ทั่วทั้งองค์กรผ่านโปรโตคอล RDP, SMB, WinRM และ NetExec

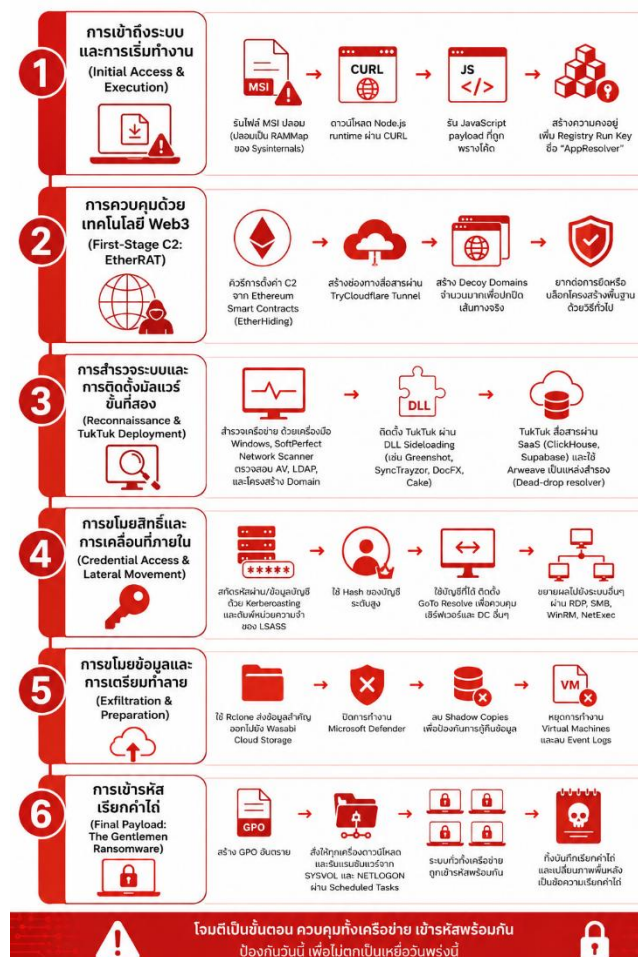


การขโมยข้อมูลและการเตรียมทำลาย (Exfiltration & Preparation)

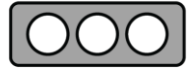
ผู้โจมตีใช้เครื่องมือ Rclone ในการส่งข้อมูลสำคัญปริมาณมากออกไปยังคลาวด์ส่วนตัวบน Wasabi Cloud Storage ก่อนที่จะปล่อยแรนซัมแวร์ จากนั้นจึงดำเนินการล้างรอยหลักฐานอย่างเป็นระบบ ด้วยการปิดการทำงานของ Microsoft Defender, ลบ Shadow Copies เพื่อป้องกันการกู้คืนข้อมูล, หยุดการทำงานของ Virtual Machines และลบ Event Logs ทั้งหมดออกจากระบบ

การเข้ารหัสเรียกค่าไถ่ (Final Payload: The Gentlemen Ransomware)

ผู้โจมตีสร้าง Group Policy Object (GPO) อันตรายเพื่อสั่งให้ทุกเครื่องในโดเมนดาวน์โหลดและรันแรนซัมแวร์จากแชร์โฟลเดอร์ SYSVOL และ NETLOGON ผ่าน Scheduled Tasks ผลที่ตามมาคือระบบทั่วทั้งเครือข่ายถูกเข้ารหัสลับพร้อมกัน มีการทิ้งบันทึกเรียกค่าไถ่ไว้ทุกเครื่อง และเปลี่ยนภาพพื้นหลังหน้าจอเป็นข้อความแจ้งเตือนการเรียกค่าไถ่



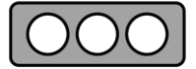
[ภาพที่ 5 แผนภาพแสดงภาพรวมลำดับการโจมตีของกลุ่ม Threat Actor]



การวิเคราะห์แหล่งที่มาของผู้โจมตี (Attribution Analysis)

จากการวิเคราะห์เชิงเทคนิค พบหลักฐานที่บ่งชี้ถึงความเชื่อมโยงกับผู้โจมตีที่มีศักยภาพสูงดังนี้ ประการแรก มัลแวร์ EtherRAT มีความคล้ายคลึงของ Loader Pattern (AES-256-CBC) กับมัลแวร์ BeaverTail ที่ใช้ในแคมเปญ Contagious Interview ซึ่ง Sysdig และ Google Threat Intelligence Group (GTIG) ระบุว่าเชื่อมโยงกับกลุ่ม UNC5342 ของเกาหลีเหนือ (DPRK) ประการที่สอง eSentire พบว่า Ethereum Smart Contract ที่ใช้ในการเก็บข้อมูล C2 ปรากฏในเหตุการณ์หลายครั้งที่เชื่อมโยงกับแคมเปญเดียวกัน รวมถึงการโจมตีผ่าน IT Support Scam ใน Microsoft Teams

อย่างไรก็ดี ณ ขณะนี้ยังไม่สามารถระบุตัวตนผู้โจมตีได้อย่างแน่ชัด เนื่องจากยังขาดหลักฐานเชิงโค้ดโดยตรง (Direct Code Overlap) ที่เพียงพอ Sysdig ระบุว่าความคล้ายคลึงที่พบอาจเป็นผลจากการแบ่งปันเทคนิคระหว่างกลุ่ม DPRK หลายกลุ่ม มากกว่าการกระทำของกลุ่มเดียวกัน นอกจากนี้ The Gentlemen RaaS ซึ่งเป็นผู้ดำเนินการปลายทาง มีรูปแบบ Affiliate ที่เปิดรับสมาชิกอย่างกว้างขวาง ทำให้การเชื่อมโยงระหว่างผู้โจมตีที่ใช้ EtherRAT/TukTuk กับผู้ดำเนินการแรนซัมแวร์โดยตรงยังต้องการหลักฐานเพิ่มเติม



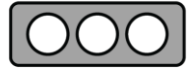
Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่าง ๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1566.001	Phishing: Spearphishing Attachment
Execution	T1204.002	User Execution: Malicious File
	T1059.007	JavaScript: Command and Scripting Interpreter
	T1574.001	Hijack Execution Flow: DLL
	T1053.005	Scheduled Task/Job: Scheduled Task
Persistence	T1547.001	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder
Privilege Escalation	T1484.001	Domain or Tenant Policy Modification: Group Policy Modification
Stealth	T1027	Obfuscated Files or Information
	T1070	Indicator Removal
	T1574.001	Hijack Execution Flow: DLL
Impair Defenses	T1629.003	Disable or Modify Tools
Credential Access	T1558.003	Steal or Forge Kerberos Tickets: Kerberoasting
	T1003.001	OS Credential Dumping: LSASS Memory
Discovery	T1082	System Information Discovery
	T1046	Network Service Discovery
	T1087	Account Discovery



Tactic	Technique ID	Technique Name
Lateral Movement	T1021	Exploitation of Remote Services
Command and Control	T1102	Web Service
	T1102.001	Web Service: Dead Drop Resolver
	T1219	Remote Admin Tools
	T1572	Protocol Tunneling
Exfiltration	T1567.002	Exfiltration Over Web Service: Exfiltration to Cloud Storage
Impact	T1486	Data Encrypted for Impact
	T1489	Service Stop

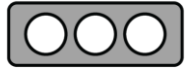


Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

URL
hxxps://witch-skins-lip-coal.trycloudflare[.]com
hxxps://fields-pct-easier-vancouver[.]trycloudflare[.]com
hxxps://howto-tar-naturals-coordination[.]trycloudflare[.]com
hxxps://workshop-lighting-protective-customs[.]trycloudflare[.]com
hxxps://afford-effect-construct-tricks[.]trycloudflare[.]com
hxxps://rapids-lil-lending-charleston[.]trycloudflare[.]com
hxxps://when-architectural-cdna-faster[.]trycloudflare[.]com
hxxps://mode-exit-legendary-trusted[.]trycloudflare[.]com
hxxps://seasonal-estimation-heatingnecessarily[.]trycloudflare[.]com
hxxps://entered-medications-motherboardadvanced[.]trycloudflare[.]com
hxxps://walt-messaging-affairs-occurring[.]trycloudflare[.]com

Domain	Values
Clickhouse	k135neflez[.]westus3[.]azure[.]clickhouse[.]cloud
Supabase	vefbdzuaadnascpeqcn[.]supabase[.]co
Fallback http C2	borjumaniya[.]store
ClickHouse	vngz3ntdrb[.]us-east1[.]gcp[.]clickhouse[.]cloud
Supabase	muurfzqprzmdkzoibxaz[.]supabase[.]co
Neon	ep-lively-cherry-a80bmwii[.]eastus2[.]azure[.]neon[.]tech

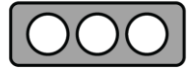


Ethereum Contracts
0xdf0b529043ef7a2bb9111bad26de624a326bacf9
0x5953f27F044779a3AFCd2BF56a4B712583Dd2E4e

Arweave Drive-Id
a6278417-39f4-407e-90bf-599f74726e66

Hashes	Values
RAMMap.msi (Initial Access)	73ce2438d4ed475e03727b7b000d2794
	3d5ee8429ef00824c0351cba507dfef92b54f83b
	d9487fdc097f770e5661f9e5dee130068cb179d33716abff1a21c8cb901f25a6
MVnVmUYj.cmd (EtherRAT)	b2d51212744f404714fd909e87254d98
	c98ee41f09ae079a5643626f57eb84f92205bb2b
	8c2665adf8bfab65463f2a9bd1b7bb0231de3f5c1e6a2e51479e44aaac2e7bf0
A7Pnj975bl.cfg (EtherRAT)	c92cf9a1af5b1fe25cdcb8771ce52be4
	b44c8084b88d31113ee51758740eb84c251bdae8
	4142d5efd4ea2abab77f2f0a917610e2ff976bf9e19d7ad1e9156eccdc5412db
v72HYLU3OpRBznc.ini (EtherRAT)	77fbe265fd65c7f7b6d323fb6de6a4fd
	114ec028a3fc4ed50056ee8166b0c39acff6ff03
	2d4b4bb18b8445e49eeda571982874403befcecf78266e3d405f6529d98bee46
log4net.dll (TukTuk)	f985b8d6d635c266fc4779dad77aa75c
	ba80d7b038758a129861e1e498e462cc3d68ae20
	19021e53b9929fdf4b7d0e0707434d56bb73c1a9b7403c8837b44d1c417198dc

Hashes	Values
smokymo.msi (GoToResolve)	b188fbc6ff5557767e73e4c883a553a3
	aa9218994798ae31a19d3e7e39cfac2e2ee55840
	1795eacd2c58894ccdd6be8854fe6456c3b069a3a873432343b57b475b256aee



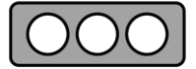
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ด้านการเฝ้าระวังเครือข่าย ให้ตรวจสอบทราฟฟิกขาออก (Outbound Network Traffic) ที่เชื่อมต่อไปยัง Web3 gateways, แพลตฟอร์ม Decentralized Storage และ SaaS แอปพลิเคชันที่ไม่คาดคิดหรือผิดปกติ
- นอกจากนี้ ควรตรวจสอบ Active Directory อย่างใกล้ชิด เพื่อค้นหาพฤติกรรมที่ผิดปกติ เช่น การพยายามทำ LDAP Enumeration, การทำ Kerberoasting และการปรับเปลี่ยน Group Policy Objects (GPO) โดยไม่ได้รับอนุญาต
- ควรติดตั้งระบบ Endpoint Detection and Response (EDR) ขั้นสูง และตั้งค่าให้สามารถตรวจจับการดัมป์ข้อมูลจาก LSASS Memory, การรันคำสั่ง PowerShell ที่ผิดปกติ และความพยายามในการไล่ปิดเซอร์วิสของโปรแกรมแอนตี้ไวรัส
- ทั้งนี้ ควรตรวจสอบการใช้งานซอฟต์แวร์โอเพ่นซอร์สข้อมูล เช่น Rclone ภายในระบบ และเฝ้าระวังทราฟฟิกขาออกไปยัง Public Ethereum RPC Providers ได้แก่ 1rpc.io, infura.io, alchemy.com และ endpoints ที่เกี่ยวข้อง รวมถึงตรวจสอบ DNS Queries ที่อาจเป็นสัญญาณของ EtherHiding-Based C2 Communication

การป้องกัน (Prevention)

- ด้านการป้องกัน องค์กรควรบังคับใช้นโยบายควบคุมการรันแอปพลิเคชัน โดยจำกัดไม่ให้มีการรันไฟล์ติดตั้ง (MSI installers) ที่ไม่ได้รับการอนุมัติจากโพลเดอร์ของผู้ใช้ (User directories) และบล็อกเส้นทางที่มีการทำ DLL Sideloadng ที่เป็นที่รู้จัก
- ควรบล็อกทราฟฟิกเครือข่ายขาออกไปยัง SaaS และ Cloud Storage ส่วนตัวที่ไม่ได้รับอนุญาต ตั้งแต่ระดับ Firewall หรือ Proxy เพื่อลดความเสี่ยงในการถูกขโมยข้อมูล (Data exfiltration)
- ควรบังคับใช้นโยบายการให้สิทธิ์เท่าที่จำเป็น (Principle of Least Privilege) แก่ผู้ใช้งานในระบบอย่างเคร่งครัด
- ควรจัดทำและควบคุมบัญชีรายชื่อ (Inventory) ของเครื่องมือประเภท Remote Monitoring and Management (RMM) ที่ได้รับอนุญาตให้ใช้งานในองค์กรอย่างเข้มงวด
- ควรจำกัดสิทธิ์การใช้งานเครื่องมือที่ใช้ในการถ่ายโอนข้อมูล (เช่น Rclone)



การรับมือ (Response)

- ด้านการรับมือ หากตรวจพบการติดตั้งโปรแกรม RMM ที่ไม่ได้รับอนุญาต หรือพบโดเมนที่เกี่ยวข้องกับโปรแกรมเหล่านั้น ให้ดำเนินการตรวจสอบ (Investigating) หรือทำการบล็อกทันที
- เมื่อตรวจพบการบุกรุก ให้แยก (Isolate) เครื่องที่ได้รับผลกระทบออกจากเครือข่ายทันที โดยเฉพาะ Domain Controllers และเซิร์ฟเวอร์หลัก เพื่อหยุดการแพร่กระจายของมัลแวร์และป้องกันการขโมยข้อมูลเพิ่มเติม
- ควรเก็บรวบรวมหลักฐานทางดิจิทัลโดยเก็บ Memory Dump, ภาพ Disk และ Network Logs ก่อนดำเนินการล้างระบบ ตรวจสอบ Registry Run Keys, Scheduled Tasks, GPO ที่ผิดปกติ และบันทึกการเปลี่ยนแปลงใน Active Directory
- ในขั้นกำจัดมัลแวร์และฟื้นฟูระบบ ให้ลบ Registry key AppResolver, ไฟล์ EtherRAT และ TukTuk ทั้งหมด รีเซ็ต Credential ของบัญชีทุกบัญชีที่อาจถูกบุกรุก ลบ GPO อันตรายที่ผู้โจมตีสร้างไว้ และกู้คืนระบบจาก Backup ที่ปลอดภัย
- สุดท้าย ควรจัดทำรายงาน Post-Incident Review เพื่อระบุช่องโหว่ที่ถูกใช้ประโยชน์ ปรับปรุง Security Awareness Training สำหรับบุคลากรด้านไอทีเกี่ยวกับการระวัง Social Engineering และ Trojanized Tools และแบ่งปัน IOC กับ MISP Platform เพื่อเสริมสร้างความมั่นคงปลอดภัยในวงกว้าง



อ้างอิง (References)

- The DFIR Report. Flash Alert: EtherRat and TukTuk C2 End in The Gentleman Ransomware. (11 พฤษภาคม 2569). <https://thedfirreport.com/2026/05/11/flash-alert-etherrat-and-tuktuk-c2-end-in-the-gentleman-ransomware/>
- Sysdig Threat Research Team. EtherRAT: DPRK uses novel Ethereum implant in React2Shell attacks. (8 ธันวาคม 2568). <https://www.sysdig.com/blog/etherrat-dprk-uses-novel-ethereum-implant-in-react2shell-attacks>
- Atos Threat Research Center. EtherRAT Distribution Spoofing Administrative Tools via GitHub Facades. (เมษายน 2569). <https://thehackernews.com/2026/04/etherrat-distribution-spoofing.html>
- MITRE ATT&CK. MITRE ATT&CK Framework. (2026). <https://attack.mitre.org/>
- Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th